

Manual 46 — Fundamentos Universais de Governança de IA

****Status:**** DESENVOLVIMENTO CONTROLADO

****Idioma:**** Português do Brasil (`pt-BR`)

****Escopo:**** Base universal e sensível às jurisdições para governança corporativa de IA.

Propósito

Este manual estabelece uma base universal para governar sistemas de inteligência artificial sem depender de um empregador, jurisdição, regulador, fornecedor, família de modelos ou arquitetura tecnológica específica. Aplica-se a IA preditiva, aprendizado de máquina, IA generativa, modelos fundacionais, sistemas RAG, IA incorporada e sistemas agênticos.

O objetivo não é impedir o uso de IA. O objetivo é permitir adoção demonstravelmente segura, lícita, controlada, útil e responsável.

Espinha dorsal universal de governança

****Responsabilização → Inventário → Classificação → Avaliação de riscos e impactos → Governança de dados → Segurança → Privacidade → Supervisão humana → Transparência → Testes e validação → Documentação → Aprovação → Implantação → Monitoramento → Gestão de incidentes e mudanças → Governança de terceiros → Evidência e auditoria → Desativação → Melhoria contínua****

Princípios fundamentais

1. Toda iniciativa de IA deve possuir proprietário de negócio e proprietário técnico claramente identificados.
2. A intensidade da governança deve ser proporcional ao risco, impacto, autonomia, criticidade, sensibilidade dos dados e exposição jurídica.
3. Governa-se o sistema completo, não apenas o modelo: dados, instruções, RAG, ferramentas, APIs, agentes, pessoas, fornecedores e infraestrutura fazem parte do escopo.
4. A governança começa antes da produção por meio de entrada, inventário, classificação, avaliação e aprovação.
5. A supervisão humana deve ser significativa: competência, informação, tempo, autoridade e capacidade real de intervir.
6. Segurança e privacidade são componentes nativos da governança de IA.
7. Decisões e controles devem produzir evidência verificável.
8. O uso de fornecedores externos não elimina a responsabilização da organização adotante.
9. O monitoramento deve detectar mudanças de desempenho, risco, modelo, fornecedor, dados, ferramentas, permissões e obrigações regulatórias.
10. A governança deve viabilizar inovação responsável sem impor controles desproporcionais a usos de baixo risco.

Módulo 1 — Mandato e modelo operacional

Definir patrocínio executivo, escopo, apetite de risco, autoridade decisória, escalonamento e separação entre primeira, segunda e terceira linhas.

****Evidência:**** estatuto de governança de IA, políticas, matriz de decisões, termos de referência do comitê e vínculo com o apetite de risco.

Módulo 2 — Inventário de IA

O inventário é o sistema de registro da governança. Deve incluir identificador, finalidade, proprietários, modelo/fornecedor/versão, usuários, populações afetadas, dados, terceiros, geografia, nível de risco, autonomia, supervisão humana, validação, aprovação, monitoramento, mudanças, incidentes e desativação.

Módulo 3 — Classificação de risco, impacto e autonomia

Avaliar impacto sobre pessoas e direitos, saúde e segurança, criticidade do negócio, exposição financeira, sensibilidade de dados, privilégios de cibersegurança, autonomia, reversibilidade, escala, uso externo/interno, classificação regulatória, concentração e necessidade de explicabilidade ou contestação.

A classificação determina profundidade da avaliação, revisores obrigatórios, independência da validação, autoridade de aprovação e frequência de monitoramento.

Módulo 4 — Avaliação de riscos e impactos

Cobrir riscos estratégicos, regulatórios, de direitos humanos, segurança física, desempenho do modelo, qualidade/proveniência de dados, privacidade, cibersegurança, abuso, viés, transparência, propriedade intelectual, terceiros, resiliência, autonomia, fraude e reputação.

Usar a estrutura:

****Cenário → Causa → Impacto → Risco inerente → Controle → Risco residual → Responsável → Decisão****

Módulo 5 — Governança de dados e conhecimento

Controlar linhagem, proveniência, finalidade autorizada, qualidade, minimização, dados sensíveis, retenção, separação entre treinamento e avaliação quando pertinente, autorização de corpus RAG, permissões de recuperação, correção, exclusão e termos de uso de dados de fornecedores.

Prompts, contexto, bancos vetoriais, índices, embeddings e conjuntos de ajuste podem constituir ativos de informação governados.

Módulo 6 — Segurança de IA

Avaliar endpoints de modelos, identidades, APIs, segredos, pipelines, prompts, instruções de sistema, recuperação, ferramentas, plugins, permissões de agentes, dependências e telemetria.

Controles-chave: privilégio mínimo, proteção de credenciais, validação de entradas/saídas, resistência a prompt injection, prevenção de exfiltração, integridade de dependências, detecção de ataques, contenção e recuperação.

Módulo 7 — Supervisão humana significativa

Definir quais decisões exigem revisão humana, quem pode aprovar ou substituir, quais informações o revisor recebe, tempos de resposta, limites de escalonamento, capacidade de interromper ou suspender e registro de intervenções.

Um revisor sem tempo ou autoridade real não constitui controle efetivo.

Módulo 8 — Testes, avaliação, verificação e validação

Avaliar desempenho pretendido, robustez, casos extremos, abuso, segurança, privacidade, equidade quando relevante, explicabilidade, fatores humanos, recuperação de falhas, factualidade/confabulação em GenAI, qualidade da recuperação RAG e limites de ações agênticas.

A independência da validação deve aumentar com a materialidade.

Módulo 9 — Portões de aprovação do ciclo de vida

****Entrada → Inventário → Classificação → Avaliação → Projeto/Aquisição → Validação → Aprovação → Implantação → Monitoramento → Mudança/Revalidação → Desativação****

Decisões possíveis: aprovar, aprovar com condições, rejeitar, adiar, conceder exceção temporária, suspender ou retirar.

Módulo 10 — Governança de terceiros

Avaliar governança do fornecedor, segurança, privacidade, uso de dados, limitações do modelo, subcontratados, processamento geográfico, mudanças, incidentes, evidência de assurance, continuidade, obrigações contratuais, saída e portabilidade.

Módulo 11 — IA generativa

Adicionar controles para confabulação, prompt injection, vazamento de informação, governança RAG, validação de saídas, proveniência e rotulagem de conteúdo quando aplicável, propriedade intelectual, red teaming, guardrails e comportamento seguro de contingência.

Módulo 12 — IA agêntica

Governar ações, não apenas conteúdo. Controlar identidade do agente, finalidade delimitada, autenticação, autorização, privilégio mínimo, allowlists de ferramentas/APIs, isolamento de credenciais, limites de transação/recursos, aprovações humanas, segregação de funções, proveniência de ações, monitoramento em tempo de execução, desligamento emergencial, delegação entre agentes e revalidação após mudanças.

Módulo 13 — Monitoramento contínuo

Monitorar deriva, erros, taxas de intervenção humana, resultados prejudiciais, eventos de segurança e privacidade, uso não autorizado de ferramentas, exceções, achados em aberto, mudanças de modelo/fornecedor e revalidações vencidas.

Cada indicador deve possuir responsável, limite, frequência, fonte de evidência e resposta definida.

Módulo 14 — Gestão de incidentes e mudanças

Ciclo de incidente:

****Detectar → Conter → Preservar evidência → Avaliar impacto → Escalonar/Notificar → Remediar → Validar → Aprender****

Mudanças materiais incluem modelo, versão, fornecedor, instruções, dados, fontes RAG, ferramentas, permissões, população usuária, geografia, finalidade ou aumento de autonomia.

Módulo 15 — Evidência e assurance

Cadeia universal:

****Requisito ou Risco → Objetivo de controle → Atividade de controle → Responsável → Frequência/Gatilho → Evidência → Procedimento de teste → Exceção → Remediação → Decisão de risco residual****

Níveis de assurance: autoavaliação da primeira linha, desafio/testes da segunda linha, validação independente, auditoria interna e assurance externo quando apropriado.

Módulo 16 — Governança executiva e do conselho

Reportar inventário por nível de risco, sistemas de alto impacto, status de validação/aprovação, aceitações de risco residual, exceções, achados críticos, incidentes, concentração de fornecedores, exposição regulatória e KRIs frente ao apetite de risco.

Cenários práticos

1. Assistente GenAI interno

Avaliar acesso, confidencialidade, dados, RAG, outputs, fornecedor, monitoramento e uso aceitável.

2. IA voltada ao cliente

Avaliar impacto, explicabilidade, contestação, validação, supervisão e transparência.

3. Triagem de candidatos por IA

Avaliar fornecedor, proveniência, equidade, supervisão, aplicabilidade jurídica e evidência.

4. RAG sobre informação sensível

Avaliar autorização de repositórios, permissões por documento, bancos vetoriais, atualidade, vazamento de dados e injeção indireta.

5. Agente autônomo de atendimento

Avaliar identidade, permissões, ferramentas, limites, aprovações humanas, segregação, logs, monitoramento e parada de emergência.

6. Assistente de programação

Avaliar confidencialidade de código, dependências, segredos, licenças, revisão e testes de segurança.

7. Automação de baixo impacto

Aplicar proporcionalidade sem controles excessivos.

8. Mudança material de modelo do fornecedor

Exigir notificação, testes de regressão, reavaliação, rollback e revalidação.

9. Incidente de IA

Conter, preservar evidência, avaliar impacto, notificar quando aplicável, remediar e revalidar.

10. Pergunta do conselho

Responder onde existe maior risco de IA e como se demonstra que os controles funcionam.

Domínios mínimos de controle

- GOV-01 Responsabilização de IA.
- INV-01 Integridade do inventário.
- CLS-01 Classificação de risco/autonomia.
- RSK-01 Avaliação de riscos e impactos.
- DAT-01 Governança de dados/conhecimento.
- SEC-01 Revisão de segurança de IA.
- PRV-01 Avaliação de privacidade.
- HUM-01 Supervisão humana significativa.
- VAL-01 Testes e validação.
- APP-01 Aprovação de implantação.
- TPR-01 Governança de terceiros.
- MON-01 Monitoramento contínuo.
- CHG-01 Mudanças materiais e revalidação.
- INC-01 Gestão de incidentes de IA.
- AUD-01 Evidência e assurance.
- RET-01 Desativação e retirada.

Critério de conclusão

A pessoa que concluir o Manual 46 deve ser capaz de pegar qualquer caso de uso de IA e construir uma cadeia rastreável desde finalidade e propriedade até classificação, riscos, controles, evidência, aprovação, monitoramento, incidentes, mudanças e decisão de risco residual.